

School of
Engineering and Computer Science
Te Kura Mātai Pūkaha, Pūrorohiko

Threat Modeling with STRIDE

Example

CYBR 271 T2 2024

Ian Welch

CAPITAL THINKING.
GLOBALLY MINDED.
MAI I TE IHO KI TE PAE



VICTORIA UNIVERSITY OF
WELLINGTON
TE HERENGA WAKA

1

This lecture

- Modelling threat modelling using STRIDE

2

Helpdesks

3

3

- **Data Flow Diagram (or DFD):** A map of how data flows through a system and where it is processed, stored, and shared between different systems.

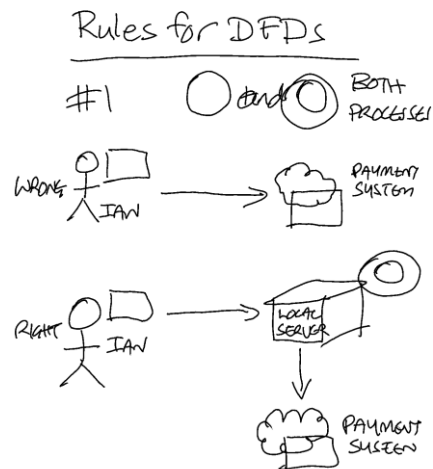
Item	Symbol	
Data flow	One way arrow	
Data store	Two parallel horizontal lines	
Process	Circle	
Multi-process	Two concentric circles	
Interactors	Rectangle	
Trust boundary	Dotted line	

4

4

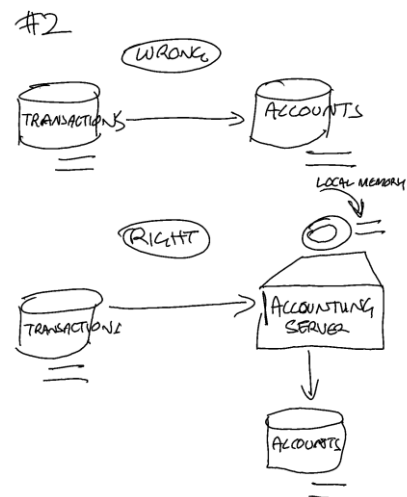
Rules for DFDs

- 1. Data cannot flow between two interactors** – Data flow must be from interactor to a process or a process to an entity. There can be multiple data flows between one interactor and a process.



Rules for DFDs

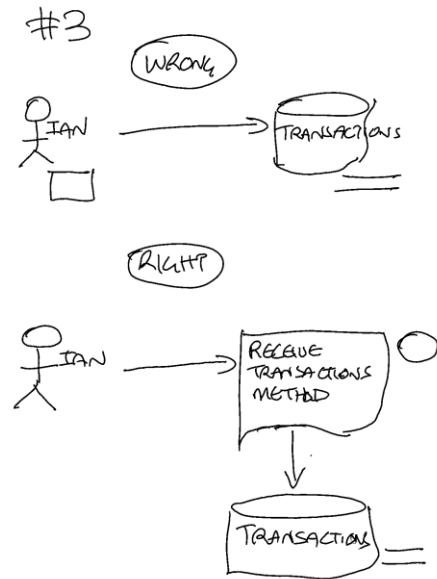
- 2. Data cannot flow between two datastores** – Data flow must be from datastore to a process or a process to a datastore. Data flow can occur from one data store to many processes.



Rules for DFDs

3. Data cannot flow directly from an interactor to data store –

Data Flow from entity must be processed by a process before going to data store and vice versa.



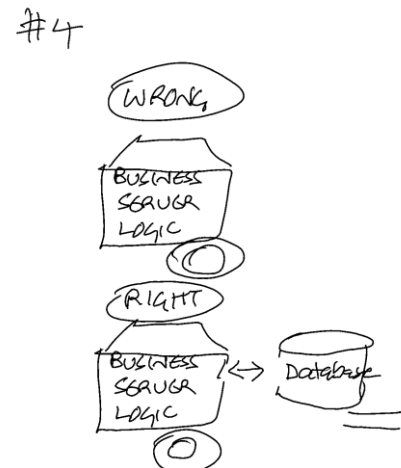
CYBR 271: Secure Programming

Slide 7

7

Rules for DFDs

4. A process must have at least one input data flow and one output data flow – Every process must have input data flow to process the data and an output data flow for the processed data.



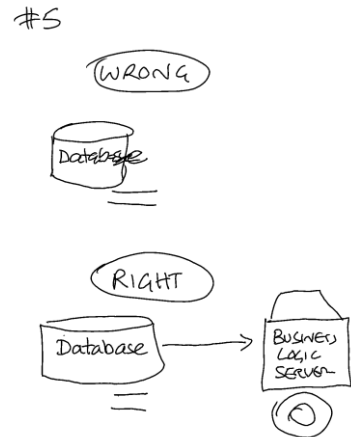
CYBR 271: Secure Programming

Slide 8

8

Rules for DFDs

5. A data store must have at least one input data flow and one output data flow – Every data store must have input data flow to store the data and an output data flow for the retrieved data.



CYBR 271: Secure Programming

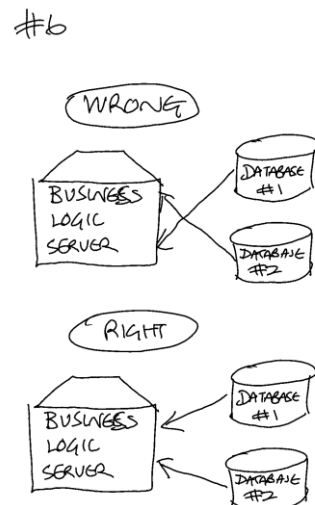
Slide 9

9

Rules for DFDs

6. Two data flows can not cross each other and all processes must be linked to minimum one data store or any other process/interactor.

<https://www.geeksforgeeks.org/rules-for-data-flow-diagram/>



CYBR 271: Secure Programming

Slide 10

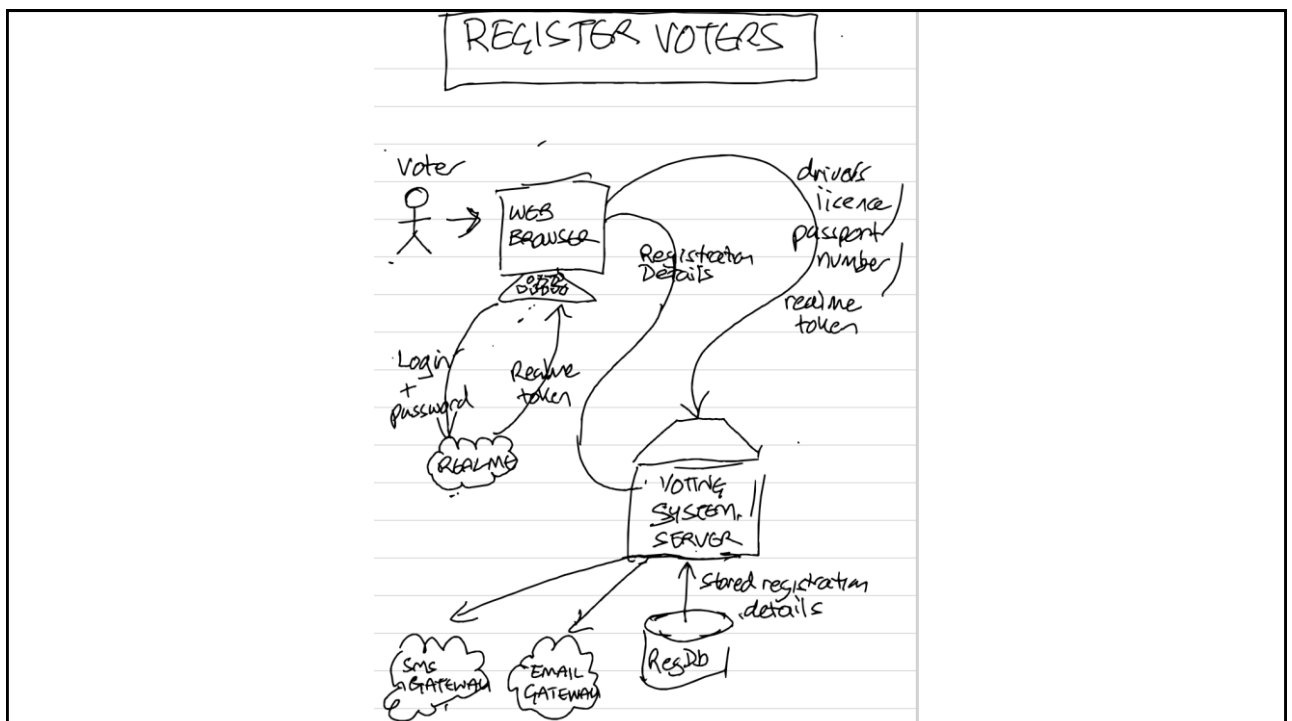
10

Use case – register voters

1. Person **visits** voting website.
2. Person provides **name** and **registered address AND MOBILE PHONE NUMBER AND EMAIL**
3. System **compares** with the details of file, and if they match the person **must now verify themselves**.
4. Person can verify either by:
 1. providing their **driver licence** details
 2. providing their **passport number**
 3. Using **RealMe**
5. Once verified person registered as elector for election and **access code** sent via **mobile phone number** or **email**

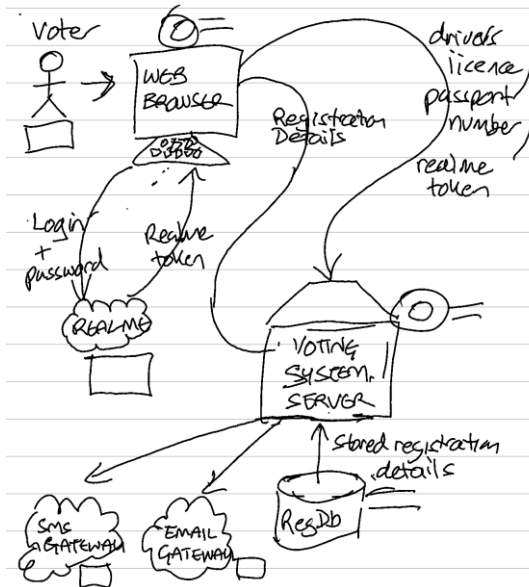
11

11



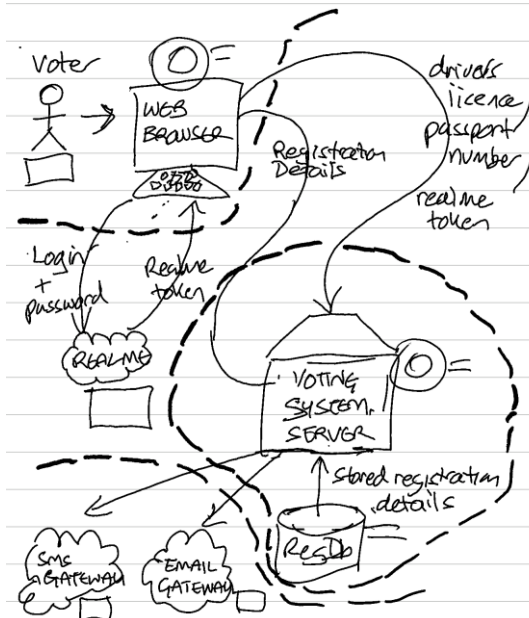
12

REGISTER VOTERS



13

REGISTER VOTERS



14

STRIDE

Type	Description	Security Control
Spoofing	Threat action aimed at accessing and use of another user's credentials, such as username and password.	Authentication
Tampering	Threat action intending to maliciously change or modify persistent data, such as records in a database, and the alteration of data in transit between two computers over an open network, such as the Internet.	Integrity
Repudiation	Threat action aimed at performing prohibited operations in a system that lacks the ability to trace the operations.	Non-Repudiation
Information disclosure	Threat action intending to read a file that one was not granted access to, or to read data in transit.	Confidentiality
Denial of service	Threat action attempting to deny access to valid users, such as by making a web server temporarily unavailable or unusable.	Availability
Elevation of privilege	Threat action intending to gain privileged access to resources in order to gain unauthorized access to information or to compromise a system.	Authorization

15

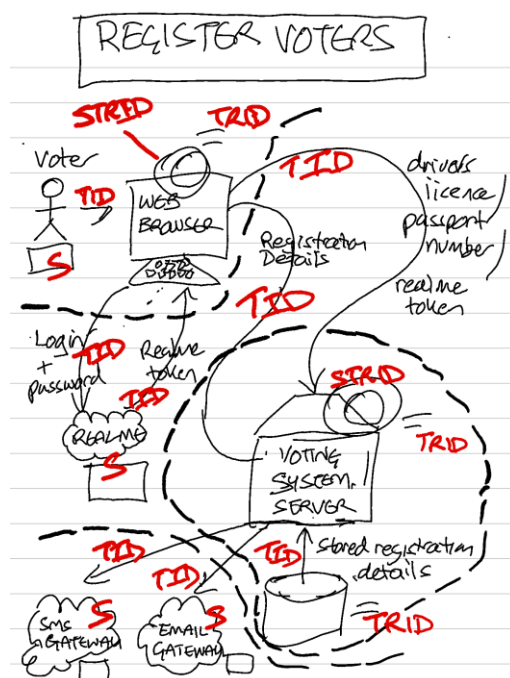
The threats

- **Spoofing:** The act of pretending to be another user, device or system and emulating traffic they might send/actions they might take
- **Tampering:** The unauthorized/malicious modification of data
- **Repudiation:** The ability to conduct an action within a system and deny ownership of that action
- **Information disclosure:** A loss of data confidentiality as a result of unauthorised disclosure of information
- **Denial of service:** Interacting with a system or service in such a way that it is unable to provide service or functionality to other users.
- **Escalation of privilege:** Gaining access to systems, data or functionality that exceed your assigned access privileges.

16

	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Escalation of Privilege
Data flow		X		X	X	
Data store		X	X	X	X	
Process	X	X	X	X	X	X
Multi-process	X	X	X	X	X	X
Interactors	X					

17



18

What does spoofing the user mean?

- someone sits down @ computer
- provides info, your registered address, their mobile phone, their email

WHAT'S THE EFFECT?

- to do anything need additional info
- if found $\leq \begin{matrix} 2 \\ 3 \end{matrix}$
- can break.
- so threat combines.

19

What about tampering with web browser

- virus? steal data, inject information
- effects: $\begin{matrix} \nearrow \\ \searrow \end{matrix}$ effect
- $\begin{matrix} \nearrow \\ \searrow \end{matrix}$ info disclosure
- $\searrow$ next step

Info disclosure →
web browser =
a what can you achieve?

20